

الوحدة 02: مبادئ الأمن الأساسية

Least Privilege (مبدأ الصلاحيات الأقل)

مبدأ **Least Privilege** يعني أن المستخدم أو البرنامج يجب أن يحصل فقط على أقل الصلاحيات اللازمة لأداء مهمته. لا أكثر ولا أقل. هذا يقلل من سطح الهجوم (Attack Surface).

تطبيق مبدأ Least Privilege

في Linux، تعديل صلاحيات ملف:

```
chmod 755 script.sh
```

يمنح المالك صلاحية القراءة والكتابة والتنفيذ (rwx)، والمجموعة والآخرين صلاحية القراءة والتنفيذ فقط (r-x). لا يحق لأي شخص آخر الكتابة على الملف.

في Windows باستخدام **icacls**:

```
icacls C:\Data\Secret.txt /grant "User1:(R)" /inheritance:r
```

يمنح المستخدم User1 صلاحية القراءة فقط (R) للملف، ويلغي الوراثة لمنع أي صلاحيات إضافية. هذا تطبيق عملي لـ Least Privilege.

Separation of Duties - SoD (فصل الصلاحيات)

مبدأ **فصل الصلاحيات** يتطلب أن المهام الحساسة تحتاج إلى أكثر من شخص واحد لإنجازها. لا يمكن لشخص واحد أن يكون لديه صلاحية تنفيذ عملية خطيرة بالكامل بمفرده.

مثال: في البنك، الموظف الذي يوافق على القرض ليس هو نفسه الموظف الذي يصرف المبلغ.

تطبيق SoD في Active Directory

إنشاء مجموعة أمان جديدة في Active Directory:

```
New-ADGroup -Name "HR-Admins" -GroupScope Global -GroupCategory Security
```

ينشئ مجموعة أمان اسمها HR-Admins بصلاحيات محددة. يتم إضافة أعضاء مختلفين إلى مجموعات مختلفة بحيث لا يمتلك شخص واحد صلاحيات شاملة.

Defense in Depth (الدفاع المتعمق)

استراتيجية تستخدم طبقات متعددة من الدفاع بحيث إذا اخترق المهاجم طبقة واحدة، تبقى الطبقات الأخرى لصدّه. مثل البصل - طبقات متعددة.

- الطبقة الأولى: جدار الحماية
- الطبقة الثانية: نظام كشف التسلل (IDS)
- الطبقة الثالثة: التشفير
- الطبقة الرابعة: التحكم في الوصول
- الطبقة الخامسة: التدريب الأمني للمستخدمين

Diversity of Defense (تنوع الدفاع)

استخدام منتجات أمنية من بائعين مختلفين لتجنب وجود نقطة فشل واحدة. إذا كان جدار الحماية من شركة A ونظام كشف التسلل من شركة B، فاختراق أحدهما لا يعني اختراق الآخر.

Zero Trust (الثقة الصفرية)

مبدأ "لا تثق بأحد أبداً، تحقق دائماً". لا يُسمح لأي جهاز أو مستخدم بالوصول إلى الموارد بشكل افتراضي، حتى لو كان داخل الشبكة الداخلية. كل طلب وصول يتم التحقق منه.

- تجزئة الشبكة (Micro-segmentation)
- المصادقة متعددة العوامل (MFA)
- التسجيل والمراقبة المستمرة

(SASE (Secure Access Service Edge

إطار أمني يجمع وظائف الشبكة والأمن في خدمة سحابية واحدة. يشمل: SWG (بوابة الويب الآمنة)، CASB (وسيط أمن السحابة)، ZTNA (وصول الشبكة ذو الثقة الصفرية)، وFWaaS (جدار الحماية كخدمة).

شرح أوامر القيادة

:chmod 755

```
chmod 755 file.sh
```

تفسير الأرقام: rwx = 7 (المالك)، r-x = 5 (المجموعة)، r-x = 5 (الآخرين). الرقم يتكون من: 4 (قراءة) + 2 (كتابة) + 1 (تنفيذ).

:icacls

```
icacls C:\Folder /grant "User:(R,W)" /grant "Admin:(F)"
```

يمنح المستخدم صلاحية القراءة والكتابة، والمسؤول صلاحية كاملة (Full Control).

:New-ADGroup

```
New-ADGroup -Name "SecurityAuditors" -SamAccountName "SecAud" -GroupCategory Security -
```

ينشئ مجموعة أمان شاملة في Active Directory لتطبيق مبدأ فصل الصلاحيات.

(Quick Quiz (MCQ

1. The Principle of Least Privilege means :

- a) All users have full access
- b) Users get only the minimum access needed
- c) Admins have no privileges
- d) Access is granted permanently

Answer: b

2. What does Separation of Duties (SoD) prevent ?

- a) Insider threats
- b) Single points of failure
- c) Data loss
- d) Network outages

Answer: b

3. Which is NOT a layer of Defense in Depth ?

- a) Encryption
- b) Policies
- c) Single firewall only
- d) Access controls

Answer: c

4. What command changes file permissions on Linux ?

- a) icacIs
- b) chmod
- c) netsh
- d) certutil

Answer: b

5. Zero Trust architecture is based on :

- a) Trusted internal networks
- b) Never trust, always verify
- c) Password-only authentication
- d) Firewall-only security

Answer: b